

MAPEO DETALLADO: MÉTRICAS → REQUISITOS NORMATIVOS

Trazabilidad de cada métrica EPSS a regulaciones aplicables en España

Versión: 1.0

Fecha: Enero 2026

TABLA MAESTRA: MÉTRICA → REGULACIÓN

Métrica A1: Cobertura EPSS (% CVEs con EPSS score)

Regulación	Artículo/Control	Requisito Específico	Evidencia Métrica	Cumplimiento
NIS2	Art. 21(E)	Gestión de vulnerabilidades basada en riesgo	Cobertura EPSS >80% = "medidas proporcionales" posibles	✓ Crítico
GDPR	Art. 32	Medidas técnicas de seguridad documentadas	Documentar que ≥80% CVEs tienen predicción riesgo	✓ Importante
ENS	SD.05	Control de vulnerabilidades técnicas	Cobertura >70% demuestra evaluación sistemática	✓ Importante
ISO 27001	A.12.6.1	Evaluación de vulnerabilidades	EPSS como técnica de evaluación documentada	✓ Importante

Métrica A2: MTTR Vulnerabilidades Críticas (EPSS ≥ 0.50)

Regulación	Artículo	Requisito	Evidencia	Cumplimiento
NIS2	Art. 21(E)	Remediación proporcional al riesgo	MTTR <7 días para EPSS ≥ 0.50 demuestra "proporcionalidad"	✓ Crítico
NIS2	Art. 19(1)	Notificación autoridades <24h para críticos	MTTR como SLA previene escalación a reguladores	✓ Crítico
GDPR	Art. 32	Medidas técnicas efectivas	MTTR bajo = respuesta rápida a riesgos de datos	✓ Importante
ENS	SD.05	SLA remediación vulnerabilidades	MTTR métrica de cumplimiento	✓ Importante

Métrica A3: Efficiency EPSS (% explotadas de priorizadas)

Regulación	Artículo	Requisito	Evidencia	Cumplimiento
NIS2	Art. 21(E)	Eficacia de priorización basada en riesgo	Efficiency >60% demuestra que EPSS discrimina bien	✓ Importante
GDPR	Art. 32	Medidas técnicas $\geq$ requeridas	Eficiencia de priorización valida adecuación técnica	✓ Importante

Métrica B1: MTTD (Mean Time to Detect) - Incidentes

Regulación	Artículo	Requisito	Evidencia	Cumplimiento
NIS2	Art. 21(C)	Monitoreo de seguridad en tiempo real	MTTD <24 horas = "tiempo real" posible	✓ Crítico
GDPR	Art. 33	Detección rápida de breaches	MTTD bajo reduce tiempo breach-to-notification	✓ Crítico
ENS	SF.01	Detección de ataques	MTTD métrica de capacidad detección	✓ Importante

Métrica C1: MTTE (Mean Time to Escalate) - a reguladores

Regulación	Artículo	Requisito	Evidencia	Cumplimiento
NIS2	Art. 19(1)	Notificación autoridades <24h	MTTE <24h = cumplimiento legal	✓ Crítico
GDPR	Art. 33(1)	Notificación autoridades <72h	MTTE <72h = cumplimiento GDPR	✓ Crítico
ENS	CP05	Procedimiento notificación incidentes	MTTE documentado en procedimiento	✓ Importante

Métrica D1: Phishing Click Rate (%)

Regulación	Artículo	Requisito	Evidencia	Cumplimiento
NIS2	Art. 21(D)	Concienciación en ciberseguridad	Click rate <15% demuestra efectividad capacitación	✓ Importante
GDPR	Art. 32	Capacitación personal en seguridad	Click rate como métrica de retención capacitación	✓ Importante
ENS	SP.01	Conciencia en seguridad	Phishing simulations validar capacitación	✓ Importante

Métrica E1: % Decisiones Priorización documentadas

Regulación	Artículo	Requisito	Evidencia	Cumplimiento
NIS2	Art. 21(E)	Proporcionalidad demostrable	Documentación EPSS en decisiones = proporcionalidad auditable	✓ Crítico
GDPR	Art. 32	Medidas técnicas documentadas	Trazabilidad decisiones = cumplimiento documentado	✓ Crítico
Auditoría Interna	ISO 19011	Auditoría de conformidad	Documentación permite verificación independiente	✓ Importante

MATRIZ SECUNDARIA: REGULACIÓN → MÉTRICAS

NIS2 - Art. 21 (Gestión de Riesgos - Medidas Técnicas)

Letra	Requisito	Métricas que Evidencian	Clase
(E)	Gestión vulnerabilidades	A1 Cobertura, A2 MTTR, A3 Efficiency, E1 Documentación	Crítica
(C)	Monitoreo seguridad	B1 MTTD	Crítica
(D)	Conciencia empleados	D1 Phishing Click	Importante

GDPR - Art. 32 (Medidas Técnicas y Organizativas)

Requirement	Métricas	Clase
Seguridad técnica	A1, A2, A3, B1	Crítica
Capacitación personal	D1	Importante
Documentación	E1	Importante

ENS - Controles de Seguridad

Control	Métrica	Clase
SD.05 (Vulnerabilidades)	A1, A2	Crítica
SF.01 (Detección)	B1	Importante
SP.01 (Conciencia)	D1	Importante

CONCLUSIÓN: TRAZABILIDAD COMPLETA

Cada métrica EPSS:

- ✓ Mapea a ≥1 regulación aplicable en España
- ✓ Resuelve pregunta de negocio (GQM)
- ✓ Tiene puntuación PRAGMATIC (8.1-8.7/10 promedio)
- ✓ Es auditable y documentable

Recomendación: Implementar todas métricas Clase A y B documentando mapeo regulatorio.

*Mapeo desarrollado por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad
Enero 2026*